RootMe: Write Up

Plataforma: TryHackMe

Máquina / Desafio:	RootMe
Dificuldade:	Fácil
Data de Resolução:	17 de agosto de 2026
Autor:	Alan Dias (alankk)

17 de agosto de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

4 Escalada de Privilégios **5**

5 Conclusão **5**

6 Referências **6**

1 Visão Geral

A máquina RootMe é um desafio voltado para iniciantes na plataforma TryHackMe, com foco na exploração de serviços web básicos e permissões em ambientes Linux. A superfície de ataque se concentra primariamente em uma aplicação web que contém um recurso de envio de arquivos vulnerável. O caminho geral para o comprometimento total engloba técnicas de enumeração de diretórios para a descoberta de áreas restritas, o desvio (*bypass*) de validações de entrada para obtenção de acesso remoto inicial, e, por fim, o abuso de binários do sistema configurados indevidamente (com permissões especiais) para a elevação de privilégios.

2 Reconhecimento

A fase de reconhecimento inicializou-se com uma varredura de portas utilizando o `nmap`. O objetivo foi identificar os serviços expostos e suas respectivas versões.

```
nmap -A <TARGET_IP>
```

Resultado do Nmap (trecho relevante):

```
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux;
   protocol 2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
```

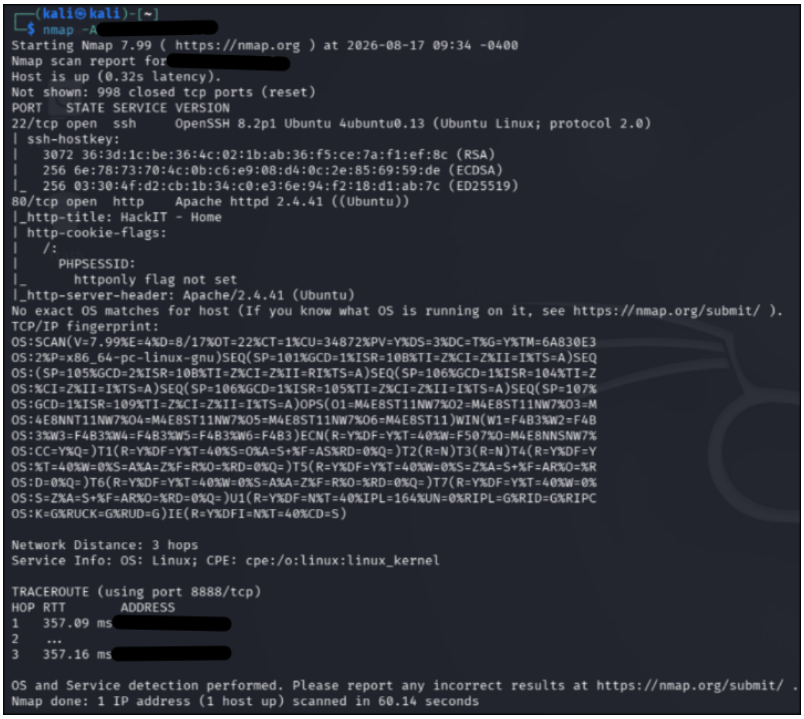


Figura 1: Resultado da varredura de portas com Nmap.

A varredura revelou apenas duas portas abertas no servidor alvo:

- **Porta 22 (SSH):** Serviço `ssh` rodando OpenSSH versão 8.2p1.

- **Porta 80 (HTTP):** Servidor web rodando Apache versão 2.4.41.

Com a identificação de um servidor web ativo na porta 80, o próximo passo lógico foi a enumeração de diretórios. Utilizando a ferramenta `gobuster` para mapear a estrutura do site, foi possível descobrir diretórios ocultos bastante promissores:

```
gobuster dir -u <TARGET_IP> -w /usr/share/wordlists/dirb/common.txt
```

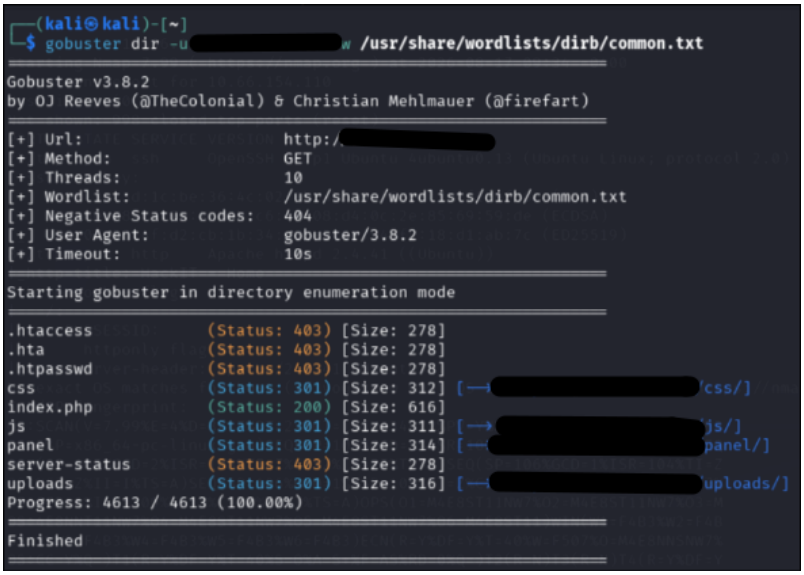


Figura 2: Enumeração de diretórios utilizando Gobuster.

- **Diretórios Ocultos Encontrados:** `/panel/` e `/uploads/`

Este diretório sugere uma área de upload ou painel administrativo que servirá como vetor primário na fase de exploração.

3 Exploração

Ao acessar o diretório `/panel/`, foi identificado um formulário para upload de arquivos. Sendo o servidor web um Apache rodando PHP, a primeira tentativa lógica foi realizar o upload de um script malicioso (baseado no `php-reverse-shell` do PentestMonkey).

Contudo, ao tentar enviar um arquivo com a extensão `.php` padrão, a aplicação retornou um erro informando que o formato não era permitido, evidenciando uma restrição no lado do servidor.

Para contornar esse filtro, utilizou-se a técnica de *extension bypass*. A extensão do arquivo foi alterada para `.php5`, que é frequentemente interpretada como código PHP em servidores Apache, mas pode passar despercebida por filtros mais fracos. O upload desse novo arquivo foi concluído com sucesso.

Sabendo através do `gobuster` que existia um diretório `/uploads/`, era altamente provável que os arquivos estivessem armazenados lá. Antes de executar o payload, um *listener* foi iniciado localmente utilizando o Netcat.

```
nc -lnvp 4444
```

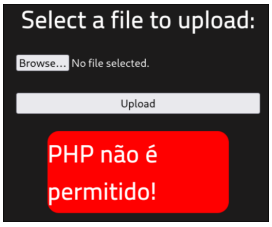


Figura 3: Erro ao tentar realizar o upload de um arquivo .php padrão.

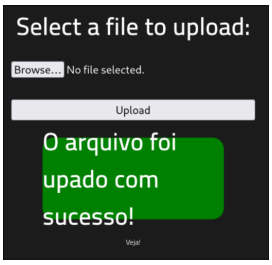


Figura 4: Upload bem-sucedido após o bypass de extensão usando .php5.

Ao acessar o caminho do arquivo recém-enviado pelo navegador (`http://<TARGET_IP>/uploads/php-reverse-shell.php5`), o código PHP foi executado pelo servidor.

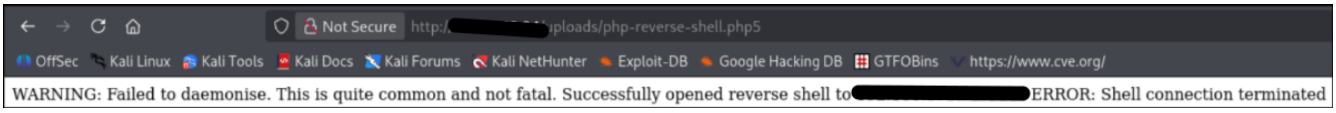


Figura 5: Execução do payload acessando o arquivo no diretório /uploads/.

Como resultado da execução, a conexão reversa foi estabelecida. O Netcat recebeu a sessão com sucesso, garantindo o acesso inicial (*foothold*) à máquina como o usuário `www-data`.

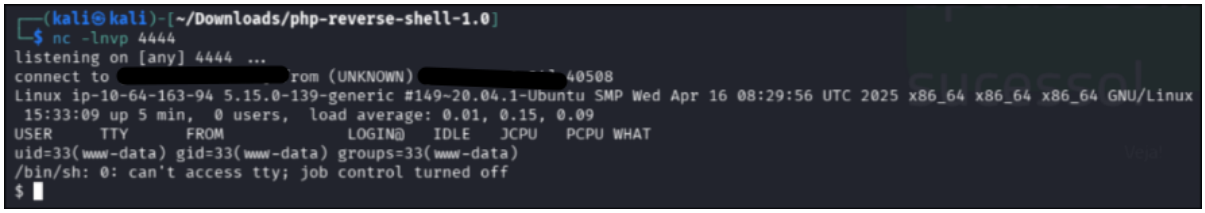


Figura 6: Acesso inicial obtido via reverse shell no Netcat.

Logo após obter a shell, a flag de usuário (`user.txt`) foi localizada e lida com sucesso no diretório `/var/www/`.

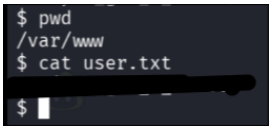


Figura 7: Captura da flag de usuário.

4 Escalada de Privilégios

Para obter privilégios administrativos (root), o processo de enumeração local foi iniciado buscando por binários que possuíssem a permissão SUID habilitada:

```
find / -type f -perm -4000 2>/dev/null
```

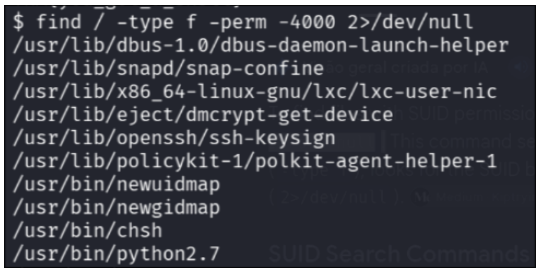


Figura 8: Enumeração de binários SUID.

A saída do comando revelou que o binário `/usr/bin/python2.7` possuía a permissão SUID, o que configura uma falha de segurança severa. Consultando a documentação no GTFOBins, identificou-se um vetor direto de exploração. Ao executar o Python para abrir um processo do shell `sh` passando a *flag* `-p`, o binário preserva os privilégios efetivos do seu proprietário original (neste caso, `root`).

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

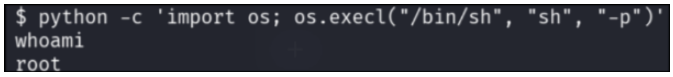


Figura 9: Escalada de privilégios executada com sucesso via Python.

Após a execução, o comando `whoami` retornou `root`, confirmando o comprometimento total do sistema. Restou apenas navegar até o diretório `/root` para capturar a *flag* final.

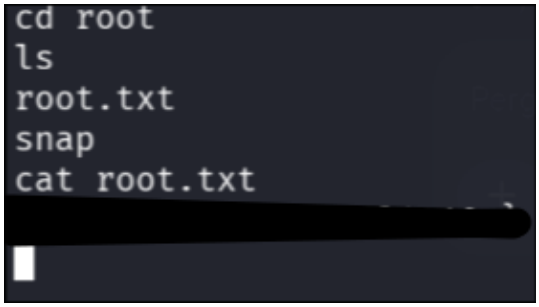


Figura 10: Captura da flag de root.

5 Conclusão

A máquina RootMe apresentou um cenário clássico de vulnerabilidades web aliadas a más configurações de permissões no Linux. O acesso inicial foi alcançado por meio de um formulário de upload de arquivos

que contava com um filtro de extensões falho, contornado de forma simples pela extensão `.php5`. A escalada de privilégios foi atingida explorando a permissão SUID indevidamente atribuída ao binário do Python, o que nos permitiu criar uma shell com privilégios máximos e obter o controle absoluto da máquina.

6 Referências

- **PHP Reverse Shell – PentestMonkey:**
  https://pentestmonkey.net/tools/web-shells/php-reverse-shell
- **Python – GTFOBins:**
  https://gtfobins.org/gtfobins/python/#shell